

HTL - HUMAN TRUST LAYER / X-TRUST

Archive v15 - 7 octobre 2026

1. IDENTITE

- Nom : HTL - Human Trust Layer. Marque : X-Trust.
- Standard ouvert HTTP. Header signe : X-Trust: v1.payloadB64.sigB64.
- Payload : {sub, score, iat, exp, kid, jti}.
- Signature actuelle : HMAC-SHA256. Migration Ed25519 + JWKS prevue.
- Doctrine : annoter, jamais bloquer. Zero KYC, zero PII.
- Positionnement : complementaire a Web Bot Auth (IETF).
- Mission : devenir un STANDARD (comme HTML), pas un SaaS.
- Fondateur : Dieng, Cote d'Ivoire, solo, tablette, 4h/2j au cyber cafe.
- Pas de smartphone. Fichiers sur Proton Drive. Mots de passe sur support separe.

2. ETAT ACTUEL

Publie et verifie en prod :

- npm @htl-syterme/htl-core 1.1.0 (kid + jti)
- JSR @htl-syterme/htl-core 1.1.0
- PyPI htl-verify 1.0.0 + htl-sign 1.0.0
- npm @htl-syterme/express-x-trust 1.0.0
- 8 Edge Functions Supabase : hyper-responder, trust-counter, quick-task, weekly-report, design-partner, honeypot, security-report, backup
- Dashboard GitHub Pages : htl-syterme.github.io/htl-core
- Compteur live : 4 verifications reelles

Securite appliquee cette session :

- 22 tests d'attaque verts (forgery, tampering, TTL bornes, jti unicite)
- Nonce anti-replay race-free : jti + upsert ON CONFLICT ignoreDuplicates
- Garde anti-navigateur sur generateTrustToken (throw si window/document)
- TTL unifie a 120s (etait 60s dans le code, incoherent avec la spec)
- kid ajoute au payload (preparation Ed25519)
- 2FA npm reactivee

Infrastructure :

- GitHub Actions : monitor 15 min, watchdog 2h, backup 48h, keepalive 3j, issue-auto-reply
- UptimeRobot : 2 monitors 5 min
- Cap 50k requetes/jour
- Rotation secret GELEE volontairement (absence fondateur)

3. CE QUI A ETE FAIT CETTE SESSION

- Retrait total Paddle/pricing/tarifs du site + pages legales
- THREAT-MODEL.md cree (235 lignes, honnete sur les limites)
- Pitch aligne 'signal' pas 'proof' partout (README + dashboard)
- URLs Supabase corrigees dans app.js (typo szbx -> szxb)
- JS casse du dashboard repare (commentaire non ferme bloquait init)
- Compteur reparu : 4
- ATTACKS.md + test/attacks.test.mjs (22 tests verts)
- Badge '20 attack tests' dans README
- Branche backups creee + workflow backup.yml reecrit et vert
- Publication @htl-syterme/htl-core 1.1.0 sur npm + JSR
- Publication @htl-syterme/express-x-trust 1.0.0 sur npm

4. VERDICT FABLE (audit externe)

Resume brutal :

- Le projet a une valeur technique réelle, mais sa valeur produit et standard est non démontrée.
- 6 semaines à répondre 'est-ce que je peux construire ça ?' -> OUI.
- Nouvelle question : 'quelqu'un d'autre veut-il l'utiliser ?' -> NON DÉMONTRÉ.
- Infra 8 Edge Functions pour 4 vérifications = disproportionnée.
- Adversaire réel : pas Web Bot Auth, mais Turnstile, reCAPTCHA, WAF, Bot Manager.
- Probabilité client payant en 12 mois (comme SaaS) : 2/10.
- Comme standard open source : hypothèse crédible à tester.

5. PLAN 30 JOURS (adapte à contrainte 4h/2j)

Règle absolue : interdiction de nouvelle Edge Function, badge, ou dashboard pendant 30 jours.

Chaque session = 4 blocs d'1h :

- BLOC 1 (1h) - Sécurité bloquante : UN seul PO par session
- BLOC 2 (1h) - Conformité protocole : SPEC, vecteurs, exemples cross-langage
- BLOC 3 (1h) - Interaction externe : un dev, une issue, une question : 'pourquoi tu ne l'utiliserais pas ?'
- BLOC 4 (1h) - Doc + commit + backup + prépa prochaine session

Critère de décision à J+30 (2 sur 3 suffisent pour continuer) :

- 1 intégration externe (PR acceptée par un tiers)
- 1 implémentation indépendante vérifiée (Go, Rust, autre)
- 3 retours écrits de devs citant une raison précise

6. POINT EXACT DE REPRISE

Au prochain démarrage :

- Vérifier docs/status.json toujours récent (monitor actif)
- Gmail : npm support + design partners + réponses prospects
- GitHub issues nouvelles -> répondre (30 min rule)
- Migrer Ed25519 + JWKS si 1h dispo
- Bloc 3 : 1 interaction externe réelle

7. INFORMATIONS CRITIQUES

- Supabase : pixmqidaoszxbdxfrrx (PAS de 'b' avant dxfrxx)
- GitHub : htl-syterme / htl-core
- npm : @htl-syterme (2FA ACTIVE)
- JSR : @htl-syterme
- PyPI : htl-syterme
- Paddle : en review (pour plus tard, pas critique maintenant)
- Design : #000 / #fff / #8e8e93 / SF Pro
- Terme 'signal' JAMAIS 'proof'
- Jamais mentionner IA/Claude publiquement
- Secret dans le chat = BRÛLE immédiatement
- Pas de smartphone. Sessions 4h/2j au cyber café.